

General Data Protection Regulation (GDPR)
Регламент защиты персональных данных

Регламент защиты персональных данных

- Регламент защиты персональных данных GDPR устанавливает **цели, принципы, общие правила защиты** физических лиц в отношении обработки персональных данных, их свободного перемещения в рамках Евросоюза, включая трансграничную передачу данных.

- Регламент GDRP вступил в силу 25.05.2018

- Ратифицирован Европарламентом в апреле 2016



Регламент защиты персональных данных

- Регламент GDPR закрепляет в том числе следующие принципы обработки персональных данных. Персональные данные должны:

  – быть обработаны **правомерно, справедливо и прозрачно** в отношении субъекта данных («принцип законности, справедливости и прозрачности»);

  – быть собраны для **определенных, четких и законных целей** и в дальнейшем не обрабатываться способом, несовместимым с этими целями;

  – быть обработаны **адекватно и ограничиваться целями**, для которых они обрабатываются (принцип «минимизации данных»);

Регламент защиты персональных данных

- быть **обработаны точно** и там, где это необходимо, а также должны обновляться (принцип «точности»);

- храниться в форме, позволяющей идентифицировать субъекта данных, **не дольше**, чем это необходимо для целей, для которых персональные данные обрабатываются («принцип ограничения хранения данных»);

- быть обработаны таким образом, чтобы обеспечить надлежащую **сохранность персональных данных**, включая защиту от несанкционированной или незаконной обработки и случайной потери, уничтожения или повреждения, с использованием соответствующих технических или организационных мер («принцип целостности и конфиденциальности»)

Регламент защиты персональных данных

- Правомерность обработки данных оценивается исходя из следующих требований и условий:
  - субъект данных **дал согласие** на обработку его персональных данных для одного или более конкретных целей;
  - обработка необходима **для исполнения договора**, стороной которого субъект данных является стороной или для принятия мер по просьбе субъекта данных до заключения контракта;
  - обработка необходима для соблюдения соответствующих **обязательств контроллера**;
  - обработка необходима **для защиты** жизненных интересов субъекта данных или другого физического лица;
  - обработка необходима для **выполнения определенных задач** и осуществляется в общественных интересах или для исполнения функций контроллера;
  - обработка необходима для законных целей и **интересов регулятора** третьих лиц.

Регламент защиты персональных данных

- В контексте содержания Регламента GDPR к субъектам, осуществляющим «обработку» «персональных данных», относятся «контролер» и «обработчик»

  – «**Персональные данные**» – означают любую информацию, относящуюся к идентифицированному или идентифицируемому физическому лицу («субъект данных»);

  – «**Обработка**» – означает любую операцию или набор операций, которые совершаются с ПДн или набором ПДн, с использованием автоматизированных средств и без таковых, в числе которых сбор, запись, организация, структурирование, хранение, переработка или изменение, поиск и выборка, экспертиза, использование, раскрытие посредством передачи, рассылка или иной способ предоставления для доступа, группировка или комбинирование, отбор, стирание или уничтожение;

Регламент защиты персональных данных

– «**Контролер**» – это физическое или юридическое лицо, государственный орган, агентство или иной орган, который самостоятельно или совместно с другими, определяет цели и средства обработки персональных данных

– «**Обработчик**» – это физическое или юридическое лицо, государственный орган, агентство или иной орган, который обрабатывает персональные данные от имени и по поручению контролёра.

Регламент защиты персональных данных

- Регламент GDPR закрепляет, что **контролёр обязан**:
  - в определенных случаях сотрудничать с обработчиками данных;
  - вести учетную документацию;
  - осуществлять оценку воздействия обработки персональных данных на права субъектов данных для некоторых видов обработки данных;
  - внедрять механизмы защиты данных;
  - в момент сбора персональных данных предоставлять субъектам данных полную информацию о целях сбора персональных данных, о правах субъектов данных и т.д.;
  - обязаны, по возможности, в течение 72 часов уведомлять национальные органы по защите данных (Data Protection Authorities) об обнаружении утечек персональных данных, и соответствующих субъектов персональных данных

- **Обработчик обязан**:
  - вести письменный реестр операций по обработке персональных данных, выполненных от имени и по поручению каждого контролёра;
  - если у обработчика нет **представителя** в Евросоюзе, он обязан назначить такое лицо в определенных случаях;
  - без задержек уведомлять контролёра об утечках персональных данных;
  - участвовать в деятельности по трансграничной передаче данных.

Регламент защиты персональных данных

- Кроме того, контролёры и обработчики, в рамках своих программ отчетности обязаны **назначить инспектора** по защите данных. Согласно Регламенту GDPR, инспектор по защите данных в обязательном порядке назначается в следующих случаях:

  – обработка данных осуществляется государственным органом;

  – основная деятельность контролёра или обработчика связана с такой обработкой данных, которая по своему охвату, целям и сути, требует крупномасштабного, регулярного и систематического мониторинга субъектов данных; при обработке специальной категории данных.

Регламент защиты персональных данных

- Территориальная сфера применения Регламента защиты персональных данных GDPR ограничивается переделами Европейского Союза, однако юридически действие Регламента GDPR распространяется на субъектов за пределами Европейского Союза.





Регламент защиты персональных данных

- Под действие Регламента GDPR подпадают контролёры или обработчики, которые не учреждены в Евросоюзе в случаях, когда:

  a. обработка персональных данных субъектов данных в Евросоюзе **связана с предложением товаров или услуг** субъектам данных в Евросоюзе, независимо от того, связано это с их с оплатой или нет.

Регламент защиты персональных данных

- При этом Регламент GDPR устанавливает, что признаками, которые с очевидностью свидетельствуют о намерении предлагать товары или услуги субъектам данных в Евросоюзе, являются:

  – использование языка или валюты, обычно используемой в одном или нескольких государствах-членах, с возможностью заказывать товары и услуги на этом языке;

  – упоминание потребителей или пользователей, которые находятся в Евросоюзе

Регламент защиты персональных данных

b. обработка персональных данных субъектов данных, находящихся в Евросоюзе при **мониторинге действий/поведения** субъектов данных в Евросоюзе, постольку, поскольку их действия совершаются на территории Евросоюза.

Регламент защиты персональных данных

- Для того, чтобы определить, подпадает ли деятельность по обработке данных для целей мониторинга действий субъекта данных, устанавливается факт того, осуществляют ли физические лица деятельность в Интернете, в том числе потенциальную возможность последовательного использования технологии обработки персональных данных и т.д.

Регламент защиты персональных данных

- Таким образом Регламент GDPR распространяется на российских операторов персональных данных (телекоммуникационные компании, интернет-компании) как на компании, не учреждённые в Евросоюзе, но обрабатывающие персональные данные находящихся в Евросоюзе субъектов данных, если их деятельность по обработке данных связана с предложением товаров и услуг таким субъектам данных в Евросоюзе, вне зависимости от того, требуется ли оплата от субъекта данных, либо связана с мониторингом деятельности субъектов данных постольку, поскольку она осуществляется в Евросоюзе.

Регламент защиты персональных данных

- В практическом плане сказанное означает,
  - во-первых, что российские компании, «ориентированные» на субъектов в Евросоюзе (потребители Евросоюза), после 26 мая 2018 г. оказались в сфере действия Регламента GDPR.
  - во-вторых, такие компании должны назначить своего представителя в Евросоюзе (пункт (80) Преамбулы Регламента GDPR).

Регламент защиты персональных данных

- «**Представитель**» – это физическое или юридическое лицо, созданное в Евросоюзе, которое специально уполномочено в письменной форме контролёром или обработчиком и представляет контролёра или обработчика, в отношении их соответствующих обязательств, предусмотренных Регламентом (Статья 4 Регламента GDPR). Порядок и основные функции представителя регулируются Статьей 27 Регламента GDPR.

Регламент защиты персональных данных

- **Представитель** может не назначаться, в частности, когда
  - обработка носит случайный характер,
  - не включает в себя масштабную обработку конкретных категорий персональных данных,
  - либо обработка персональных данных, связана с уголовными приговорами и правонарушениями,
  - или если контролёр является органом или учреждением государственной власти.

Регламент защиты персональных данных

- **Представитель** должен действовать от имени контролёра или обработчика, может взаимодействовать с любыми компетентными органами Евросоюза, государства-члена, включая надзорные органы.
- **Представитель** должен быть специально уполномочен, посредством письменного предписания контролёра или обработчика, действовать от их имени в отношении их обязательств, вытекающих из Регламента GDPR.
- Назначение такого **представителя** не влияет на ответственность или обязанности контролёра или обработчика вытекающие из Регламента GDPR.

Регламент защиты персональных данных

- **Представитель** должен выполнять свои задачи согласно предписанию, полученному от контролёра или обработчика, и осуществлять любые действия в целях обеспечения соблюдения Регламента GDPR.

- **Представитель** подпадает под действие исполнительного производства в случае несоблюдения требований Регламента GDPR контролёром или обработчиком.

Регламент защиты персональных данных

- Если у российских операторов персональных данных (телекоммуникационных компаний, интернет-компаний), к примеру, предоставляющие услуги через Интернет для лиц в странах Евросоюза, есть представительства и филиалы в странах Евросоюза, то функции представителя могут быть возложены на них.

Регламент защиты персональных данных

- Регламент GDPR при регулировании отношений, связанных со сбором и хранением персональных данных субъектов данных исходит из обязательного требования получения «**согласия**» субъекта на обработку персональных данных.
- **Согласие** должно быть настолько же легко **отозвать**, как и **предоставить**, а для специальных категорий данных согласие должно быть явно выраженным.
- В Преамбуле Регламента GDPR разъясняется, что согласие **не считается добровольным**, если субъект данных не имеет подлинного и свободного выбора либо возможности отказать в предоставлении согласия или отозвать согласие без ущерба для себя.
- Контролёр данных обязан быть в состоянии предоставить доказательства получения согласия.

Регламент защиты персональных данных

- В настоящее время наверное преждевременно анализировать возможные коллизии между нормативными требованиями действующего российского законодательства, и нормами Регламента GDPR.

- Так как в самом ЕС правоприменительное право только начало действовать и пока ещё не вышли разъясняющие документы. Однако попробуем сравнить то что есть.

Регламент защиты персональных данных

- В действующем российском законодательстве в регулировании отношений в сфере персональных данных системообразующим актом является Федеральный закон «**О персональных данных**» от 27.07.2006 №152

- Регламент GDPR и ФЗ РФ о персональных данных имеют различное действие в **пространстве**, **по кругу лиц**, **и во времени**.

Регламент защиты персональных данных

- ФЗ РФ о персональных данных
  - не обладает экстерриториальным действием,
  - не распространяется на нерезидентов, собирающих персональные данные российских граждан за границей, в случае, если они не осуществляют деятельность в интернете, направленную на Российскую Федерацию.

Регламент защиты персональных данных

- В контексте содержания Регламента GDPR субъектами, осуществляющим обработку персональных данных являются «**контролер**» и «**обработчик**», а в терминологии ФЗ РФ о персональных данных – «**оператор**».

- **Оператор** – государственный орган, муниципальный орган, юридическое или физическое лицо, самостоятельно или совместно с другими лицами организующие и (или) осуществляющие обработку персональных данных, а также определяющие цели обработки персональных данных, состав персональных данных, подлежащих обработке, действия (операции), совершаемые с персональными данными.

Регламент защиты персональных данных

- «Европейская модель» защищает персональные данные как основное право человека, является нейтральной к «национальному признаку».

- **Право на защиту ПДн**, согласно Регламенту GDPR, осуществляется на территории Евросоюза и в государствах-членах независимо от гражданства или проживания, тем самым не ограничивается сфера действия права о персональных данных по «национальному принципу».

Регламент защиты персональных данных

- ФЗ РФ о персональных данных **распространяется только на граждан Российской Федерации**,

- что следует из нормативных положений
  - ФЗ №242 от 21.07.2014 «О внесении изменений в отдельные законодательные акты Российской Федерации в части уточнения порядка обработки персональных данных в информационно-телекоммуникационных сетях».
  - ФЗ №149 «Об информации, информационных технологиях и о защите информации» (части 4 Статьи 16)
  - ФЗ №152 «О персональных данных» (части 5 Статьи 18, части 3 Статьи 22)

Регламент защиты персональных данных

- Таким образом, сбор персональных данных и их защита связана с гражданами России, т.е. сфера применения законов о персональных данных в российском праве **ограничена «по национальному принципу»**.

- При этом на практике **сложно**, а порой невозможно, российскому оператору данных, в частности при обработке персональных, полученных через интернет, **определить гражданство субъекта данных**.

- Как правило, интернет-услуги не предоставляются «по национальному признаку», даже если регистрационные формы могут содержать графу о гражданстве пользователя, проверить достоверность предоставленной информации по общему правилу не представляется возможным.

Регламент защиты персональных данных

- Роскомнадзор de facto «переложил» бремя идентификации гражданства субъекта данных на обработчиков данных.

- Поскольку определение способов идентификации гражданства субъекта данных может быть различным, скорее всего российские операторы данных будут собирать все персональные данные субъектов данных на территории России с тем, чтобы выполнить требования российского права.

Регламент защиты персональных данных

- **Передача персональных данных третьей стране** или международной организации может иметь место, когда Европейская Комиссия приняла решение, что третья страна, территория, или один или несколько особых секторов третьей страны, либо соответствующая международная организация **обеспечивают надлежащий уровень гарантий**.

- При этом Регламент GDPR закрепляет критерии оценки надлежащего уровня защиты, из которых должна исходить Европейская Комиссия при принятии решения.

Регламент защиты персональных данных

- Если Европейская Комиссия будет обладать соответствующей информацией, что третья страна или организация не обеспечивают надлежащий уровень защиты, она вправе отменить, изменить или приостановить решение о передаче данных.

- Европейская Комиссия опубликовала в Официальном Журнале Европейского Союза, список третьих стран, а также организаций, в отношении которых она приняла решение о том, что надлежащий уровень защиты существует, либо не обеспечивается.

Регламент защиты персональных данных

- Согласно ФЗ РФ о персональных данных, трансграничная **передача персональных данных осуществляется в иностранные государства**, которые являются сторонами Конвенции Совета Европы о защите физических лиц при автоматизированной обработке персональных данных, а также в иные иностранные государства, **обеспечивающие адекватную защиту прав субъектов персональных данных**.

- При том трансграничная передача персональных данных в иностранные государства может быть запрещена или ограничена в целях защиты основ конституционного строя РФ, нравственности, здоровья, прав и законных интересов граждан, обеспечения обороны страны и безопасности государства.

Регламент защиты персональных данных

- В РФ Роскомнадзор утверждает перечень иностранных государств, не являющихся сторонами Конвенции Совета Европы о защите физических лиц при автоматизированной обработке персональных данных и обеспечивающих адекватную защиту прав субъектов персональных данных.

- Государство, не являющееся стороной Конвенции Совета Европы о защите физических лиц при автоматизированной обработке персональных данных, **может быть включено в перечень иностранных государств**, обеспечивающих адекватную защиту прав субъектов персональных данных, при условии соответствия положениям указанной Конвенции действующих в соответствующем государстве норм права и применяемых мер безопасности персональных данных.

Регламент защиты персональных данных

- Один из наиболее важных аспектов требований российского законодательства локализации данных, в контексте трансграничной передачи персональных данных в иностранные государства связано с тем, что **сбор и первичное хранение данных (граждан РФ) должно быть локализовано на территории РФ**.

- Российские нормы локализации данных предназначены для предотвращения злоупотребления персональными данными российских граждан иностранными операторами данных.

Регламент защиты персональных данных

- Всё выше изложенное обобщённо свидетельствует о том, что Регламент GDPR и российское законодательство, регулирующее сферу персональных данных, имеют самостоятельную территориальную и «юрисдикционную» сферу применения.

- При этом некоторая общность подходов регулирования не дает основания сделать вывод относительно их «гармонизации».

- В практическом плане для российских компаний, деятельность которых связана со сферой персональных данных, ориентированных на пользователей в Евросоюзе, имеющих договорно-правовые обязательства с контрагентами Евросоюза, – это означает «**двойное обременение**».

Регламент защиты персональных данных

- Возможные риски и последствия нарушения норм Регламента GDPR для российских операторов персональных данных (интернет-компании и телекоммуникационные компании), предоставляющих услуги через интернет для лиц в странах Евросоюза непосредственно связаны с тем, что Регламент GDPR закрепляет обязанности обработчиков данных.

- К числу прямых обязанностей относятся, к примеру:

  - **ведение письменного реестра** операций по обработке персональных данных, осуществляемых от имени и по поручению каждого контролера;
  - **назначение своего представителя** в Европейском Союзе;
  - **представление уведомления** об утечках персональных данных, по возможности не позднее 72 часов после обнаружения утечки;

Регламент защиты персональных данных

- соблюдение целого ряда закрепленных механизмов, включая **механизм сертификации**;

- **предоставление** субъектам данных в момент сбора персональных данных транспарентную (прозрачную) **информацию** об обработке и о целях такой обработки;

- представление доказательств о **правомерности деятельности**, связанной по обработке (т.е. бремя доказывания возлагается, по смыслу Регламента GDPR, на лиц, обрабатывающих персональные данные субъектов данных).

- соблюдение норм, предусмотренных Статьей 83, которые подпадают под **административные штрафы**; при этом при наложении штрафов в порядке Статьи 83, всегда берется та сумма, которая больше (из двух сумм);

Регламент защиты персональных данных

- **20 млн. евро или 4%** от глобального оборота (что больше) за нарушение
  - основных принципов, прав субъектов,
  - требований к трансграничной передаче,
  - норм и требований актов национальных регуляторов.

- **10 млн. евро или 2 %** от глобального оборота (что больше) за нарушение:
  - порядка получения согласия детей,
  - непринятие технических и организационных мер защиты ПДн,
  - отсутствие представителя в ЕС,
  - неуведомления об утечках.

Регламент защиты персональных данных

- Избежать возможных рисков и последствий нарушения норм Регламента GDPR компания может посредством своевременного принятия мер, которые способны продемонстрировать соблюдение требований Регламента GDPR.

- В их числе могут быть следующие:

Регламент защиты персональных данных

1. Необходимо проанализировать операции по обработке данных на предмет добросовестности их осуществления, а также пересмотреть существующие формы уведомления субъекта данных.

- Это связано с тем, что Регламент GDPR обязывает предоставлять субъекту данных детализированную информацию:
  - об обработке данных в момент ее сбора;
  - целях обработки;
  - о правах субъекта данных (необходимо, к примеру, указать право на отзыв согласия на обработку);
  - о сроке хранения данных и др.

Регламент защиты персональных данных

2. Разработать внутренние регламенты, определяющие политику компании в сфере обработки персональных данных, включая назначение инспектора по защите данных.

Регламент защиты персональных данных

3. Осуществить «аудит», в случае наличия, действующих договоров с компаниями из Европейского Союза, на предмет правовых оснований обработки, использования, хранения и т.д. персональных данных.

- Это связано с тем, что Регламент GDPR предусматривает, наряду с согласием субъекта персональных данных на обработку, и иные правовые основания обработки.

- Правомерность обработки, к примеру, может вытекать из контрактных обязательств. Контрагенты из Европейского Союза могут потребовать внести изменения в существующие договоры для соблюдения требований Регламента GDPR. В этой связи следует, в том числе, решить вопрос: когда и как изменить (дополнить, отменить) условия действующих договоров, кто будет нести бремя расходов, связанных с такими изменениями и проч.

Регламент защиты персональных данных

4. Регламент GDPR предусматривает и регулирует порядок осуществления трансграничной (международной) передачи данных, включая условия и порядок перемещения персональных данных в третьи государства, в международные организации, а также в рамках группы компаний, осуществляющих совместную экономическую деятельность.

- При этом такая трансграничная передача данных не исключает портативности данных, «право на забвение» и иных прав субъектов данных. Соответственно, целесообразно проанализировать правомерность хранения персональных данных для обоснования того, что интересы компании (обрабатывающих персональные данные) обладают правомерной преимущественной силой по сравнению с правами субъектов данных, поскольку нередко субъекты данных обладают «завышенным пониманием» своих прав.

Регламент защиты персональных данных

5. Регламент GDPR признает обязательный характер (в правовом значении) корпоративных кодексов поведения, как регулирующий нормативный механизм «законной/правомерной» трансграничной передачи данных в рамках группы компаний/предприятий, осуществляющих совместную экономическую деятельность.

- Целесообразно проанализировать существующие (и утвержденные в будущем) корпоративные кодексы поведения. Нередко корпоративные кодексы поведения рассматривают как «золотой стандарт» регулирования передачи данных в рамках трансграничной передачи данных в рамках группы компаний/предприятий.

Регламент защиты персональных данных

- Можно смоделировать следующую ситуацию.
  - Субъект персональных данных из стран-членов Евросоюза, в соответствии с Регламентом GDPR хочет обжаловать действия российской компании-обработчика, связанные с обработкой его персональных данных, т.к. они обработаны без его согласия и такая обработка нанесла ему ущерб.
  - Субъект данных вправе обратиться в соответствующий компетентный орган.
  - Но даже если такой компетентный орган вынесет решение, оно не будет исполнимо на территории РФ, поскольку отсутствуют адекватные правовые механизмы, в том числе из-за отсутствия правовых договоров о правовой помощи.